

KC桌面——外资精译

波士顿咨询：印度BFSI的AI安全缺口，不是技术问题，是同步问题

印度金融业正站在一个危险的十字路口。波士顿咨询（BCG）与印度数据安全委员会（DSCI）联合发布的报告指出，印度BFSI（银行、金融服务与保险）行业在过去十年完成了惊人的数字化转型，超过10亿网民、6.6亿智能手机用户构成了全球最密集的金融攻击面之一。但真正让行业不安的，不是技术落后，而是防御节奏的脱节——攻击者已经用AI将漏洞利用时间压缩了90%以上，而大多数金融机构的补丁周期仍然以月为单位计算。

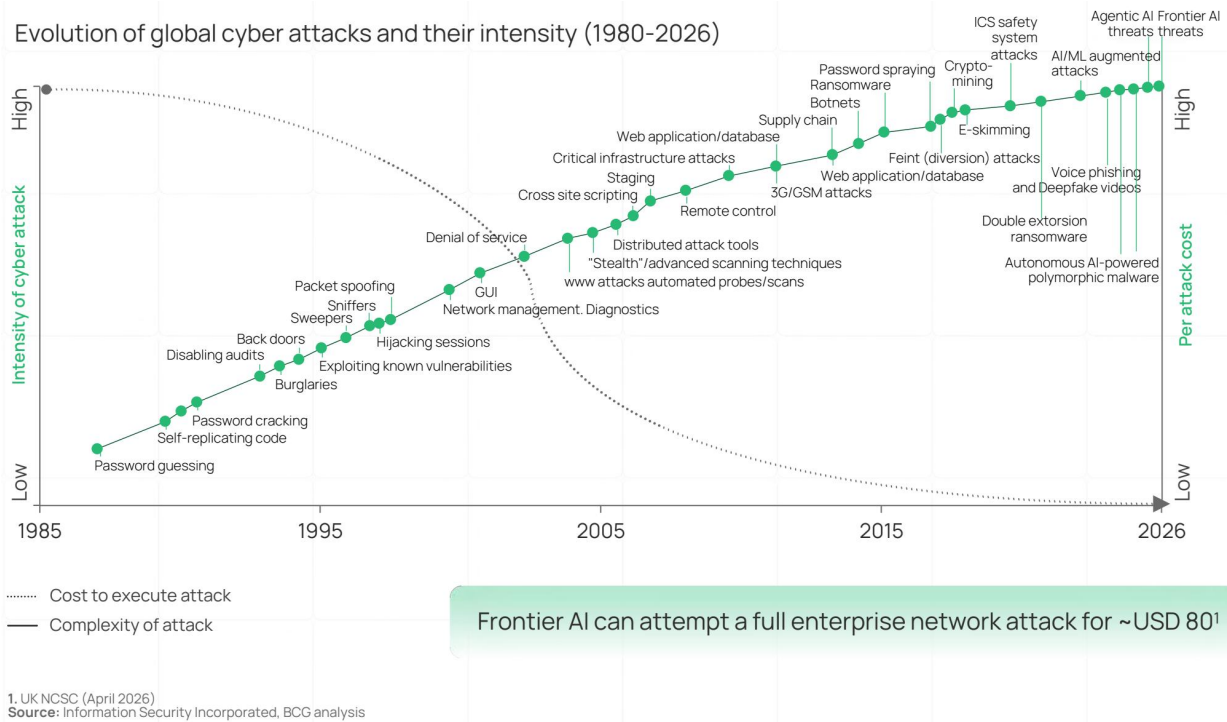
> KC评论：当攻击者用“天”来行动，而防御者还在用“月”来响应，这不是技术差距，是时间差。印度BFSI的困境对任何快速数字化的市场都有警示意义。

攻击经济学已彻底改写：成本降至80美元，时间压缩90%

报告揭示了一个残酷的现实：AI正在同时放大攻防两端的效率，但攻击侧的加速度更快。英国国家网络安全中心的数据显示，前沿AI模型可以用约80美元的成本尝试一次完整的企业网络攻击。一个仅需0.11美元/百万token运行的小型开源模型，已经成功复现了FreeBSD的漏洞利用。与此同时，漏洞披露数量自2020年以来翻倍，2024年后加速增长，其中超过一半无需身份验证即可利用。

印度BFSI面临的挑战尤为严峻。过去四年，印度计算机应急响应小组处理的网络安全事件数量翻倍。2024年7月，一次针对共享技术供应商的勒索软件攻击，导致约300家合作银行和地区农村银行的支付服务中断。2025年2月，一家顶级零售券商的云配置错误导致客户数据泄露，市值大幅蒸发。这些案例表明，攻击不再是孤立的，而是通过共享基础设施形成连锁反应。

更令人担忧的是，印度BFSI的防御信心严重不足。调查显示，只有不到15%的首席信息安全官对管理无法修补的遗留系统和嵌入式系统有高度信心；不到17%对第三方和开源依赖的可见性有高度信心。一位印度中型私营银行的首席信息安全官直言：“攻击现在以天和小时计，但我们的变更和补丁管理仍然需要1-3个月。这种速度不对称是我们最大的战斗。”



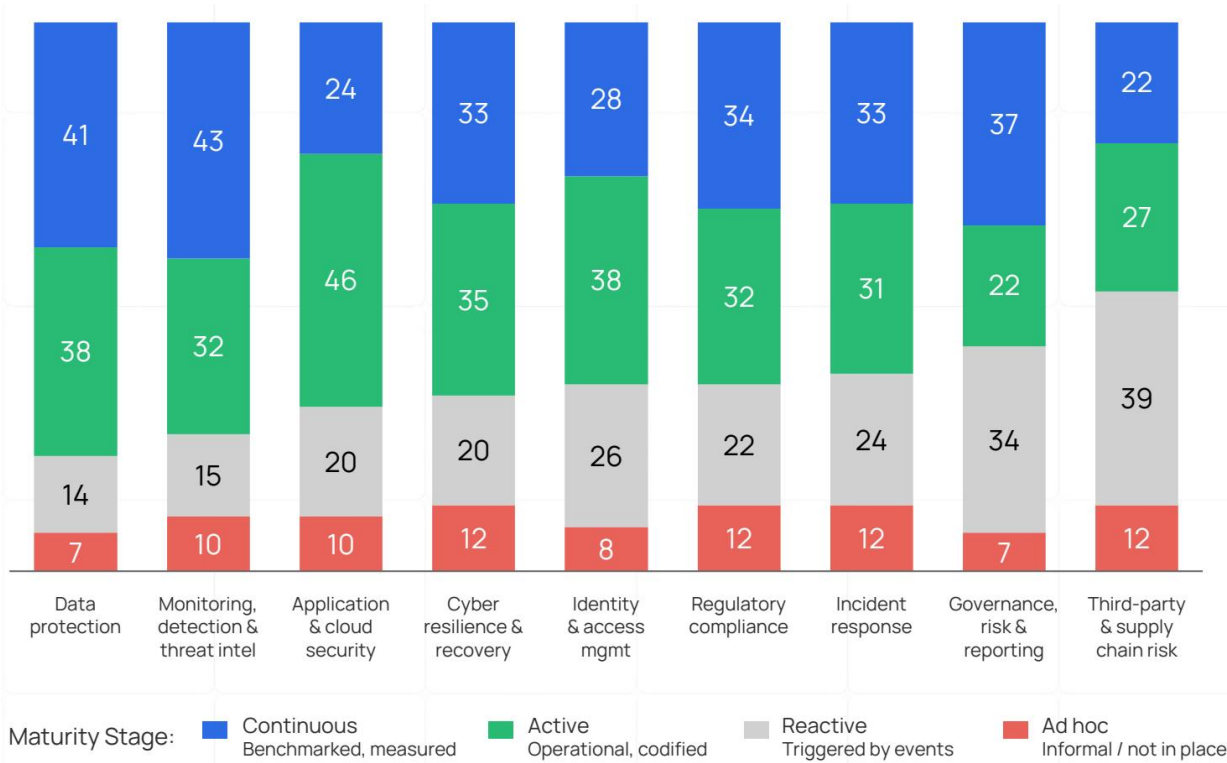
图表 1

第三方风险已成“第一方风险”：55%的CXO将其列为首要问题

报告指出，印度BFSI的第三方风险已经不再是供应链管理问题，而是直接影响业务连续性的核心风险。55%的印度BFSI高管将第三方和供应链风险列为首要关注点，但只有49%的企业拥有成熟的控制措施。这种差距主要体现在治理和连续性上——大多数机构仍然采用年度采购审查的方式管理供应商，而不是将其视为企业延伸部分进行持续监控。

集中度风险不再是假设。2024年7月的事件已经证明，一个共享技术供应商的漏洞可以同时瘫痪300家银行。报告强调，管理方式必须从“逐个供应商尽职调查”转向“系统性共享依赖关系映射”。AI进一步放大了这种风险：它降低了攻击者发现和利用第三方漏洞的门槛，同时增加了数据泄露的潜在影响。

> KC评论：当你的业务依赖第三方云服务、支付网关或核心银行系统时，他们的安全就是你的安全。印度BFSI的教训是：不要等到300家银行同时宕机才意识到集中度风险。



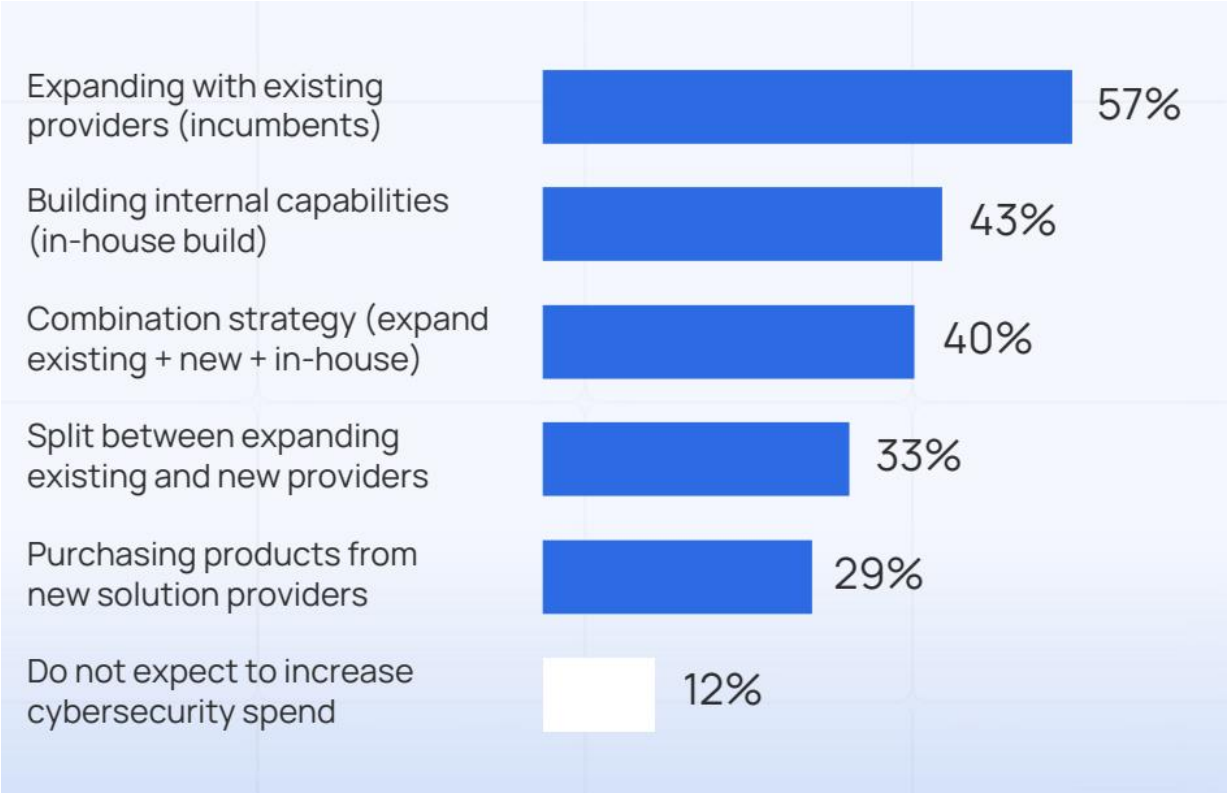
图表 2

未来12-18个月：从“安全功能”到“同步韧性系统”的转型窗口

报告提出了一个关键判断：印度BFSI的下一阶段网络安全运营模式，必须从“安全部门的议程”转向“跨五条战线的同步韧性系统”。这五条战线包括：业务对齐（网络安全优先级与业务风险一致）、跨职能团队（业务、风险、法律、IT和安全作为一个责任单元运作）、供应商管理（第三方作为企业延伸进行治理）、人员防御（内部风险和客户欺诈作为统一项目）、生态协同（威胁情报在同行、监管机构和行业机构间共享）。

目前，印度BFSI在AI治理方面存在明显短板：只有29%的企业同时拥有AI安全负责人和明确的AI安全政策。超过60%的机构将IT预算中不到10%用于网络安全，远低于全球同行水平。报告认为，未来12-18个月是决定性的窗口期——那些果断行动、实现五条战线同步的机构，将定义整个十年的行业韧性标准，并在AI驱动的金融体系中占据领先地位。

对于董事会和CEO而言，网络安全投资将比以往任何时候都更关键。报告警告，攻击者已经作为一个协调的经济体在运作。只有那些匹配这种协调性——在五条战线上实现同步防御——的机构，才能将网络韧性转化为竞争优势。否则，它们将永远处于被动反应状态，用昨天的边界防御明天的威胁。



图表 3